

HALCYON BENEFITS GROUP — AI SYSTEM INVENTORY & RISK CLASSIFICATION

Sample GRC portfolio artifact | Fictional company | Framework basis: NIST AI RMF 1.0 (Map function), EU AI Act risk tiers, ISO/IEC 42001 A.4 | Inventory date: 2026-07-15

AI ID	System Name	Business Owner	Use Case	Deployment Status	AI Type	Provider / Model	Build vs Buy	Data Inputs	Personal Data?	Decision Impact	Human Oversight Mode	EU Nexus?	EU AI Act Tier (assessed)	EU Act Rationale	NIST AI RMF Profile Applied	Inherent Risk (1-5)	Governance Status	Next Action
AI-001	ClaimSight Adjudication Assist	VP Claims Operations	Recommends approve/deny/pend on benefits claims; adjuster confirms	Production	Predictive ML (gradient boosting)	In-house model on Azure ML	Build	Claim history, plan rules, provider codes, member demographics	Yes	Determines member benefit outcomes	Human-in-the-loop (adjuster confirms each)	Yes — 3 EU-based client plans	High-Risk	Access to essential private services (insurance/benefits eligibility) — Annex III category; automated recommendation materially influences outcome. Human confirmation reduces but does not eliminate high-risk classification.	AI RMF Core + fairness testing profile	5	Ungoverned	Priority 1: full risk assessment, bias audit, oversight redesign, EU conformity path (see AI Risk Assessment)
AI-002	Member Support Chatbot	Director of Member Services	Answers plan questions, routes to agents; GenAI over plan documents	Production	Generative (LLM, RAG)	Azure OpenAI GPT-4o over indexed plan docs	Buy + configure	Member questions, plan documents, limited account context	Yes	Informational; can misdirect on coverage	Human-on-the-loop (escalation available)	Yes	Limited-Risk (transparency)	Interacts with natural persons; must disclose AI nature. Not making eligibility decisions itself, but confabulated coverage answers create indirect harm.	AI RMF Core + Generative AI Profile (AI 600-1)	4	Partially governed	Add AI disclosure banner; implement confabulation testing; log and sample review of coverage-related answers
AI-003	Fraud Pattern Detector	Director of SIU	Flags claims for special investigation review	Production	Predictive ML (anomaly)	Third-party SaaS (VigilAI)	Buy	Claims data, provider billing patterns	Yes	Triggers investigation; may delay payment	Human-on-the-loop	No	Minimal / not in EU scope	No EU nexus; if scope expands to EU plans, likely High-Risk under Annex III (essential services).	AI RMF Core	3	Partially governed	Vendor AI questionnaire; document oversight; monitor for EU expansion
AI-004	Recruiting Resume Screener	VP People	Ranks applicants for benefits-analyst roles	Pilot	Predictive ML (NLP scoring)	Third-party ATS module	Buy	Resumes, application forms	Yes	Affects hiring shortlist	Human-in-the-loop (recruiter reviews top 20)	Yes — EU-based recruiting for Dublin office	High-Risk	Employment / worker management — explicit Annex III category. Also NYC Local Law 144 exposure for NYC roles.	AI RMF Core + fairness testing profile	5	Ungoverned	Priority 1: pause pilot pending bias audit and vendor assessment (see AI Risk Assessment)
AI-005	Document Intake OCR	Director of Operations	Extracts fields from submitted forms	Production	Computer vision / OCR	Azure Document Intelligence	Buy	Scanned forms, member IDs	Yes	Data entry accuracy	Human-on-the-loop (exception queue)	Yes	Minimal	Data extraction with human exception handling; no consequential decision.	AI RMF Core (light)	2	Governed	Annual accuracy validation; keep in inventory
AI-006	Marketing Content Generator	Director of Marketing	Drafts campaign copy and member communications	Production	Generative (LLM)	ChatGPT Enterprise	Buy	Marketing briefs, brand guidelines	No	Low; human edits all output	Human-in-the-loop	No	Minimal	No personal data; all output human-reviewed before publication.	Generative AI Profile (light)	2	Governed	Acceptable use policy attestation; keep in inventory
AI-007	Analyst Copilot (M365)	CIO	Summarizes documents, drafts emails across the workforce	Production	Generative (LLM)	Microsoft 365 Copilot	Buy	Enterprise email, files, chats — potentially PHI/PII	Yes	Productivity; data exposure risk	Human-in-the-loop	Yes	Minimal (system) / Data risk (organizational)	Not a high-risk use case, but broad access to sensitive data creates data governance exposure. Governance issue is DLP and access scoping, not AI Act tier.	Generative AI Profile — data privacy & information integrity risks	3	Partially governed	Restrict Copilot indexing of PHI repositories; DLP policy for AI-generated content; usage attestation
AI-008	Actuarial Forecast Model	Chief Actuary	Projects claims cost for pricing	Production	Statistical / ML hybrid	In-house (R + Python)	Build	Historical claims, demographic aggregates	No (aggregate d)	Pricing decisions; indirect member impact	Human-in-the-loop	No	Minimal	Aggregate data, expert-reviewed outputs; model risk governance applies (SR 11-7 style), not AI Act.	AI RMF Core + model risk management	3	Governed	Annual model validation; align to model risk policy
AI-009	Shadow AI — unsanctioned tools	CISO (owner by default)	Various staff using consumer AI tools with work data	Unknown	Generative (various)	Consumer ChatGPT, Gemini, Claude free tiers	Neither — unmanaged	Unknown; likely includes member data in some cases	Likely	Data leakage; policy violation	None	Unknown	Not applicable (organizational risk)	Not a system; a governance gap. Discovered via CASB telemetry: 214 unique users hitting consumer AI endpoints in 30 days.	AI RMF Govern function	4	Ungoverned	Acceptable use policy; CASB blocking of consumer tiers; sanctioned alternative (AI-007); awareness campaign

INVENTORY SUMMARY

Counts derived from the inventory tab. Note: 9 rows includes

EU AI Act Tier	Count
High-Risk	2
Limited-Risk (transparency)	1
Minimal	3
Minimal / not in EU scope	1
Not applicable (organizational risk)	1

Governance Status	Count
Ungoverned	3
Partially governed	3
Governed	3

Systems with personal data	6
Systems with EU nexus	5
High-Risk AND Ungoverned (Priority 1)	2

HOW SYSTEMS WERE CLASSIFIED

Why an inventory first	You cannot govern what you have not enumerated. Every AI governance framework — NIST AI RMF (Map 1), ISO/IEC 42001 (A.4 resources), EU AI Act (registration obligations) — presumes an inventory exists. Most organizations do not have one; discovery via procurement records, cloud consoles, and CASB telemetry is the first real task.
Discovery sources used	(1) Procurement and SaaS spend records, (2) Azure/M365 admin consoles, (3) CASB / web proxy telemetry for AI endpoints, (4) Interviews with department heads, (5) Engineering repository scan for ML dependencies. AI-009 (shadow AI) surfaced only through source 3.
EU AI Act tiers	Unacceptable (prohibited) → High-Risk (Annex III categories incl. employment, essential private services, credit) → Limited (transparency duties, e.g. chatbots) → Minimal. Classification depends on use case and context, not on the technology. The same LLM is Minimal in marketing and Limited in a member-facing chatbot.
Human oversight modes	In-the-loop = a person confirms each output before it takes effect. On-the-loop = system acts, person monitors and can intervene. Out-of-the-loop = fully automated. Under the EU AI Act, human oversight (Art. 14) is a required control for high-risk systems, not a classification-reducing factor by itself.
Inherent risk (1-5)	Composite of decision impact, personal data sensitivity, autonomy, and population affected. Ordinal, for prioritization only — see the Risk Assessment artifact for the fuller treatment.
Timeline caveat	EU AI Act high-risk obligations were originally applicable 2 August 2026. A May 2026 'Digital Omnibus' proposal would defer standalone high-risk systems to 2 December 2027. As of this inventory that deferral is proposed, not adopted. Plans here assume the earlier date until the text is final — planning to the later date and being wrong is the costlier error.
What this is not	This is a portfolio artifact for a fictional company. It is not legal advice on EU AI Act applicability. Real classification of a high-risk system requires counsel and, for many Annex III categories, a documented conformity assessment.